

INFORME GERENCIAL DE PRUEBAS DE SEGURIDAD (RESUMIDO)

Sistema AJUDAG v2.0 | Evaluación de Postura y Controles OWASP Top 10

1. Resumen Ejecutivo y Certificación de Postura

El presente informe audita la postura de seguridad de la aplicación AJUDAG v2.0 mediante 15 controles de seguridad alineados con el estándar OWASP Top 10 (Control de Acceso, Inyección SQL/XSS, CSRF, Fuerza Bruta, Cifrado y RBAC). La postura global fue dictaminada como APTA sin vulnerabilidades críticas activas.

15 / 15 Controles Evaluados 100% Superados	94 Aserciones de Seguridad 1.8s Ejecución	0 Vulnerabilidades Activas Cero Críticos/Altos
1 Hallazgo Corregido Manejo 500 a 404	6 Fallos Pre-existentes Fuera de Alcance QA	APTA Postura Global Certificado para Prod

2. Cobertura de Categorías OWASP Evaluadas

- **OWASP A01 - Broken Access Control:** Verificación de rutas protegidas, RBAC para roles (Admin/Supervisor/Ejecutivo), bloqueo de usuarios sin rol y protección CSRF (HTTP 419).
- **OWASP A02 - Cryptographic Failures:** Verificación de almacenamiento de passwords mediante Bcrypt (\$2y\$) e imposibilidad de exposición de hashes/datos sensibles en HTML.
- **OWASP A03 - Injection (SQLi & XSS):** Validación de login y búsquedas sanitizadas con Eloquent, y escape automático de scripts HTML vía Blade ({{ }}).
- **OWASP A04 & A07 - Insecure Design & Auth Failures:** Protección contra Mass Assignment (campos is_admin/role blindados), contraseñas fuertes (mínimo 8) y Throttling contra Fuerza Bruta (HTTP 429 tras 5 intentos).

3. Hallazgo Principal de Seguridad Remediado

Remediación de Fuga de Información por Errores 500 (IDOR/Manejo Excepciones):

Se detectó que 9 controladores CRUD usaban llamadas directas 'find(\$id)' en consultas de recursos inexistentes, retornando HTTP 500 con trazas del sistema. Se aplicó la remediación sustituyendo 27 invocaciones por 'findOrFail(\$id)', logrando un comportamiento seguro con código de respuesta HTTP 404 (Validado por la prueba SEC-013).

4. Recomendaciones Prioritarias

- ✓ Agregar encabezados de seguridad HTTP (CSP, X-Frame-Options, X-Content-Type-Options, HSTS) vía Middleware.
- ✓ Habilitar HTTPS estricto en producción y forzar redirección scheme.
- ✓ Asegurar el uso de findOrFail() en controladores secundarios como AsignarController.
- ✓ Corregir inconsistencias pre-existentes de la suite funcional (redirección de AuthController y DB Refresh en Blog).

5. Conclusión Gerencial

El sistema AJUPTELCBO v2.0 DEMUESTRA UNA POSTURA DE SEGURIDAD ROBUSTA Y APTA PARA PRODUCCIÓN. Se mitigaron los riesgos de inyección y fuga de información técnica, garantizando el cumplimiento de los controles mínimos requeridos.

Entorno: SQLite en Memoria | PHP 8.4 | Laravel 13 | PHPUnit 12.5

Fecha de Certificación: 15 de Julio de 2026